

Incident Response Toolkit

Five field instruments for CISOs, from the first alert to a hardened programme

Grounded in the npm, PyPI, GitHub Actions, container and IDE-extension campaigns of 2025–2026

HOW TO USE THIS TOOLKIT

Each part is self-contained and can be printed separately. Parts 1, 2 and 4 are used during an incident and are designed to be filled in by hand; Parts 3 and 5 are prepared in advance and reviewed after every incident.

Part	Instrument	Use it when	Time frame
1	30-Minute Blast Radius Assessment	An alert says something you use may be compromised	Minutes 0–30
2	Atomic Rotation Protocol	Credentials were reachable from an affected system	Hours 0–24
3	Supply Chain IR RACI Template	Before an incident, and in its first hour	Prepare now
4	CISO Communication Playbook	Briefing the board, regulators, customers and the public	Hours 0–24
5	90-Day Hardening Roadmap	After containment, or before the next incident	Days 1–90

Conventions used throughout

Bold questions are the checks to complete; grey text explains why each one matters. Lines in red marked → are triggers to act on immediately. Owners are suggested roles; replace them with named people in your organisation. Regulatory clocks are prompts only and must be confirmed with counsel for your jurisdiction and sector.

PART 1

30-Minute Blast Radius Assessment

The CISO's first 30 minutes in a software supply chain P1 incident

Use it when an alert, advisory or vendor notice says a package, action, image or extension you use may be compromised. Start the clock at the alert.

Alert received (date / time):	Incident commander:
-------------------------------	---------------------

Work top to bottom. Run Sections 1, 2 and 4 in parallel wherever you have the people; do not wait for one to close before starting the next. Every line marked → in red is a trigger: act on it immediately, not at the 30-minute mark.

1 ENVIRONMENT AND SCOPE

Target: 0–10 min

☐	Is the flagged package or dependency version present in ANY production service? List every service that carries it, not only the one that alerted. The first alert almost never marks the full blast radius. Owner: SecOps / Engineering → If yes anywhere in production: declare a P1 now.
☐	Is it a direct dependency, or transitive (pulled in by another package)? Transitive dependencies hide from quick manual checks. They are why cascades such as the 2026 Trivy → npm → PyPI chain and PhantomRaven's remotely fetched dependencies stayed hidden for as long as they did. Owner: AppSec / Engineering → If transitive and not in your SBOM: run a dependency-tree audit across every repository.
☐	Which CI/CD pipelines or build runners executed the affected version, and when? Record exact timestamps, not “recently”. This window defines credential exposure later in this checklist and answers the regulator's “when did you know?”. Owner: Platform Engineering
☐	Can you query a current SBOM right now, or are you searching manifests by hand? Note which. Organisations with live SCA and SBOM tooling answered “are we affected?” in minutes during the largest 2025 npm worm outbreaks; those without took days. Your answer resets the time budget for the rest of this checklist. Owner: SecOps

2 CREDENTIAL EXPOSURE

Target: 10–20 min

☐	Did the affected runner or machine have write access to any package registry (npm, PyPI, internal registries)? Write access is what turns a compromised runner into a propagation engine. It is exactly how the 2025 Shai-Hulud worm and the 2026 CanisterWorm and ChainDrop worms republished themselves across maintainer accounts. Owner: SecOps / Platform Engineering → If yes: freeze publish rights for that identity now.
☐	Were cloud IAM credentials (AWS, GCP, Azure) reachable from the affected runner? Presume compromise rather than waiting for proof; these payloads are built to harvest cloud credentials and metadata tokens from CI/CD environments. Owner: Cloud Operations / CISO → If yes: begin key rotation and session revocation (see Part 2, item 3).
☐	Were GitHub personal access tokens or other long-lived tokens reachable from the runner or its environment? Long-lived tokens were the highest-value target in nearly every 2025–2026 supply chain campaign. Treat every token the runner could reach as exposed, whether or not exfiltration is proven. Owner: SecOps

☐	Were Kubernetes secrets or CI/CD service-account passwords reachable? Service accounts are often outside routine rotation. Confirm them explicitly instead of assuming a broader token rotation covered them. Owner: Platform Engineering
☐	Has rotation been started for every credential type above, as one coordinated operation? Partial rotation is not rotation. After the first 2026 Trivy breach, an incomplete rotation left the attacker with bot access, which was used three weeks later for a far larger attack. Rotate everything at once, or assume nothing is rotated. Owner: SecOps / Platform Engineering → Confirm in audit logs: zero successful authentications with any old credential.

3 EXFILTRATION AND REGULATORY CLOCKS

Target: 20–30 min

☐	Is there evidence of outbound data transfer to external servers or public repositories? Look specifically for attacker-created GitHub repositories and unfamiliar command-and-control traffic. Recent campaigns used blockchain-hosted infrastructure (Solana, Ethereum, the Internet Computer) that no registrar or host can take down. Owner: SecOps / Legal → If yes: preserve forensic evidence before any remediation touches the environment.
☐	Does the affected data include personal data of people in the EU? This determination alone starts a hard external clock. Make it early, even provisionally, rather than waiting for certainty. Owner: Legal / DPO → GDPR Art. 33: notify the supervisory authority within 72 hours of becoming aware.
☐	Could this be a material cybersecurity incident for a US-listed company? Credentials already in attacker hands can meet the materiality bar on their own, even before any customer data has moved. Start the materiality assessment now; the clock runs from its conclusion. Owner: CISO / Legal / Incident Response → SEC Form 8-K, Item 1.05: file within 4 business days of determining materiality.
☐	Are you an essential or important entity under the EU NIS2 Directive? Confirm applicability within the first 30 minutes, not after legal review later in the day; the early warning is due within a day. Owner: Legal / CISO → NIS2: early warning within 24 hours, incident notification within 72 hours, final report within one month.
☐	Are you a financial entity in scope of DORA? DORA has the tightest clock here, and it is easy to miss when the incident is first framed internally as an “engineering issue”. Owner: Legal / CISO → DORA: initial notification within 4 hours of classifying the incident as major, and no later than 24 hours after detection.
☐	Does downstream impact reach critical infrastructure? Consider this even if you are not critical infrastructure yourself: a customer or partner who is may pull your incident into scope. Owner: CISO / Legal → CIRCA (once its reporting rules are in force): 72 hours for covered incidents.
☐	Could cardholder data or payment environments be affected? Card-brand rules do not wait for the investigation to finish; suspicion or confirmation is the trigger. Owner: CISO / Legal → PCI DSS: notify your acquirer and the card brands immediately, per their rules.

Clocks and thresholds vary by jurisdiction, sector and contract. Confirm every obligation with counsel; this list is a prompt, not legal advice.

4 COMMAND, EVIDENCE AND DOWNSTREAM IMPACT

Ongoing: all 30 min

☐	Has a single incident commander been named before anything else starts? Supply chain P1s pull in SecOps, Legal, Engineering and Communications at once. Without one named owner, teams issue conflicting instructions within ten minutes. Owner: CISO → If not yet named: name one before continuing with this checklist.
--------------------------	---

☐	Has coordination moved to a channel the attacker cannot see? If the affected CI/CD environment held chat or email integration tokens, assume your normal Slack or email is visible to the attacker. Owner: <i>SecOps / IT</i> → Open an out-of-band bridge (separate tenant or phone bridge) now.
☐	Have logs, container images and affected systems been snapshotted BEFORE remediation? Rotating credentials or killing pods first destroys the chain of custody needed for forensics, insurance and law enforcement. Some 2025–2026 payloads also wiped the host when a stolen token was revoked. Owner: <i>SecOps / Forensics</i> → Snapshot and isolate first; revoke from a clean machine second.
☐	Could anything YOU publish (packages, images, extensions, releases) have been built or signed in the exposure window? In several 2025–2026 cascades a victim became a vector within hours. If your pipeline was compromised, everything you shipped in the window is suspect, not only what you consumed. Owner: <i>Engineering / AppSec</i> → If yes: treat this as a customer-facing incident.
☐	Is there evidence the compromise extends beyond the alert that started this checklist? Self-propagating worms move across maintainer accounts and repositories. Check every repository and package reachable by the same token, runner or developer. Owner: <i>SecOps / AppSec</i>
☐	Does your cyber insurance policy set its own notification clock or a mandatory forensics panel? This clock runs independently of the regulatory ones, and engaging an unapproved vendor can jeopardise cover. Owner: <i>CISO / Legal / Risk</i> → Confirm the insurer's approved vendor list before engaging outside forensics.

AT THE 30-MINUTE MARK YOU SHOULD BE ABLE TO STATE

1. Affected environments: _____
2. Credentials presumed compromised: _____
3. Regulatory clocks started, and when: _____
4. Downstream or customer impact: confirmed or ruled out: _____

PART 2

Atomic Rotation Protocol

Credential rotation checklist for a supply chain compromise

Use it when Part 1 has identified credentials that were reachable from an affected runner, machine or account. Run it in one coordinated window.

THE ATOMIC PRINCIPLE

Rotate every item below in one coordinated window, then verify every item, before anyone declares containment complete. Partial rotation is not rotation: it is the most repeated failure across the npm, PyPI and GitHub Actions campaigns of 2025–2026, and stolen credentials were reused up to five weeks after theft. If items 1 to 5 are rotated hours apart, assume the attacker kept access for the whole gap.

If you must sequence: registry publish tokens first (largest external blast radius) → cloud IAM → GitHub tokens → Kubernetes, registry and service secrets → third-party integrations.

Before you revoke: snapshot and isolate any infected machine first. Some 2025–2026 payloads wiped the host when a stolen token was revoked.

ROTATION CHECKLIST

Tick Rot. and Ver. independently

Rot.	Ver.	Credential class, action, failure mode, verification	Owner
☐	☐	1. Registry publish tokens (npm, PyPI, RubyGems, internal registries) Action Revoke every long-lived publish token tied to the affected maintainer or CI identity. Reissue through trusted publishing (OIDC) bound to a protected environment where the registry supports it; otherwise use short-lived, package-scoped tokens. Common failure In the 2025 Shai-Hulud worm some maintainers changed their password but left an automation token active, and the worm kept publishing with it. Tokens left live after the September wave were reused in Shai-Hulud 2.0 two months later. Verify Registry audit logs show zero publishes by any old token ID after the rotation timestamp.	AppSec
☐	☐	2. GitHub personal access tokens, fine-grained tokens and GitHub App keys Action Revoke every token reachable from the compromised runner or account, including tokens stored as CI secrets and bot tokens, not only the one named in the alert. Rotate GitHub App private keys and review OAuth app grants. Common failure The 2025 tj-actions/changed-files compromise (CVE-2025-30066) began with one automation-bot token. After the first 2026 Trivy breach, rotation was incomplete; the attacker kept bot access and repointed 75 of 76 action tags three weeks later. Verify Export the full token and app-grant list for the account and organisation; every entry is revoked or explicitly accounted for.	SecOps
☐	☐	3. Cloud IAM credentials (AWS, GCP, Azure) Action Rotate access keys and service-account keys for every identity or role the runner could use, in every cloud. Then kill live sessions: on AWS attach a deny for sessions issued before the rotation time (aws:TokenIssueTime); on GCP disable or delete the old keys; on Azure revoke sign-in sessions and refresh tokens. Common failure Rotating the key but not invalidating temporary credentials already issued (for example AWS STS sessions) leaves a live window the attacker can still use. Verify CloudTrail, Cloud Audit Logs and the Azure activity and sign-in logs show no successful call with an old key or pre-rotation session.	Cloud Operations

Rot.	Ver.	Credential class, action, failure mode, verification	Owner
☐	☐	4. Kubernetes secrets, container-registry tokens and CI/CD service-account passwords Action Rotate every secret and service-account credential reachable from the compromised namespace or pipeline, including Docker Hub, GHCR and ECR push tokens. Restart every pod that mounted an old secret; running pods keep the old value until they do. Common failure Checkmarx's March 2026 clean-up missed a Docker Hub publishing token, which was used five weeks later to publish malicious KICS images. Verify No running pod mounts an old secret, and registry and service-account logs show no use after rotation.	Platform Engineering
☐	☐	5. Third-party and integration tokens (chat, monitoring, alerting, webhooks, AI-provider keys) Action Rotate webhook URLs and API keys for every chat, monitoring, alerting and AI-provider integration configured in the compromised environment. Common failure This is the most commonly forgotten class. Teams rotate cloud and registry tokens and leave a Slack webhook or paging key that can spoof alerts or leak data. 2026 stealers explicitly searched for OpenAI and Anthropic keys. Verify Every integration in the pipeline's secret store has its own rotation line, not only the ones with obvious security scope.	SecOps / IT
☐	☐	6. Any credential the rotation owner is not 100% sure about Action If there is doubt about whether a credential was reachable, rotate it. An unnecessary rotation costs hours; a missed one can cost weeks of attacker access. Common failure Every partial-rotation failure in this protocol shares one root cause: someone was confident a specific credential was out of scope, and was wrong. Verify A second person independently confirms the exposure boundary before containment is declared complete.	CISO

SIGN-OFF LOG				Audit and chain of custody
Credential class	Rotated by	Time (UTC)	Verified by	Time (UTC)
Registry publish tokens				
GitHub tokens and App keys				
Cloud IAM (AWS / GCP / Azure)				
Kubernetes, registry and service secrets				
Third-party and integration tokens				
Other (specify)				

Keep watching every retired credential for 90 days and alert on any attempt to use it.

PART 3

Supply Chain IR RACI Template

Who owns what during a supply chain incident: a customisable default

Use it when preparing before an incident, and in the first hour of one to settle who decides. Customise it to your organisation before you need it.

R Responsible: does the work	A Accountable: owns the outcome; exactly one	C Consulted: input before the decision	I Informed: told afterwards
-------------------------------------	---	---	------------------------------------

These defaults reflect how response actually unfolded across 2025–2026 incidents: credential-theft worms, compromised CI/CD pipelines and malicious registry publishes. Cross out and rewrite any cell that does not match your organisation. A RACI only works if it names who really holds each role, and every activity must have exactly one A.

PHASES 1–2 DETECTION, TRIAGE AND CONTAINMENT

Activity	SecOps	Legal	Comms	Platform Eng.	AppSec	Finance	Exec
On-call escalation and P1 declaration	R/A	I		C	C		I
SBOM / dependency blast-radius query	C			C	R/A		
Credential exposure scoping	R/A	I		C			I
Forensic evidence preservation	R	C		C			A
CI/CD pipeline freeze	C			R/A	C		I
Build environment isolation / quarantine	A			R	C		
Atomic credential rotation (Part 2)	R/A			R			I
Rotation verification (audit-log check)	R/A			C			

PHASES 3–4 ERADICATION, RECOVERY AND POST-INCIDENT

Activity	SecOps	Legal	Comms	Platform Eng.	AppSec	Finance	Exec
Upstream / registry malicious-version takedown	C	C	I		R/A		I
Pipeline hardening (SHA pinning, PR-trigger audit)	C			R	A		
Clean rebuild and redeploy	C			R/A	C		
Board / executive briefing	C	C	C			I	R/A
Regulatory notification filing	C	R/A	I			I	C
Customer and downstream-partner notification	I	C	R	I			A
Public statement / media response	I	C	R				A
Cyber-insurance claim and forensics-vendor engagement	I	C				R	A
Post-incident review and 90-day roadmap ownership	R	C	I	C	C	I	A

Before you rely on it Test the template against one scenario from Part 1 in a tabletop exercise, write a named person (not only a team) next to each A, and agree a deputy for every A who can act out of hours.

PART 4

CISO Communication Playbook

*Stakeholder communication in the first 24 hours of a supply chain incident***Use it when** you must brief the board, regulators, customers, the public or another affected organisation in the first day.**TO THE BOARD**

- Lead with what is confirmed: affected systems, exposed credentials and containment status, not what is feared.
- State the decision you need now: approve customer notification, approve forensics spend, or convene the materiality assessment for an 8-K.
- Name what is still unknown and when you will have an answer, with a real time rather than “soon”.
- Give a one-line worst case so the board is not blindsided later, framed as a scenario, not a prediction.

TO REGULATORS

- Notify a credible incident inside your legal window, even before the root cause is confirmed. Clocks start at awareness or a materiality determination, not at certainty.
- State what you know, what you have done and what you are still investigating. Do not speculate to fill gaps.
- Route the wording through Legal or the DPO; engineering supplies facts, not the notice.
- Keep one consolidated log of every regulator contacted, when, and what was said.

PUBLICLY: WHAT TO SAY AND NOT SAY

- Say what you detected, what containment you took, who you are working with and when you will update next.
- **Avoid:** “No customer data was affected” before forensics confirms it. A retraction costs more credibility than a delayed statement.
- **Avoid:** Technical detail that helps the attacker adapt, such as exact patch timing or remaining tooling gaps.
- **Avoid:** Naming or blaming an upstream vendor before confirming; you may need their cooperation within hours.

THIRD-PARTY AND CROSS-ORGANISATION COORDINATION

- When the attack spans organisations, agree one named contact on each side before either says anything publicly.
- Coordinate disclosure timing jointly. A unilateral statement can start the other party's regulatory clock or contradict their message.
- Share indicators of compromise and technical detail directly with the other security team, not through public channels.
- If you are downstream of a poisoned dependency, ask the upstream vendor three questions: what did you ship, in which window, and to whom?

QUICK REFERENCE: SAY AND AVOID

SAY	AVOID
“We identified a security issue affecting [system] and took immediate containment action.”	“This was a minor issue with no impact.” (before that is confirmed)
“We are working with external specialists and will share an update by [specific time].”	“No further comment at this time.” (reads as hiding something or having no plan)
“We have no evidence of [X] at this time, and we are actively investigating.”	“There is no evidence of [X].” (implies a certainty you do not have yet)
“We have notified the relevant regulators within the required timeframes.”	Silence on regulatory compliance (invites speculation that you did not notify)

THE FIRST 24 HOURS AT A GLANCE

0–1 HOUR	1–4 HOURS	4–12 HOURS	12–24 HOURS
Confirm the incident internally and brief the board chair and CEO informally. No public statement yet.	Complete the regulatory determination (Part 1, Section 3); a DORA clock can expire inside this window. Draft, but do not send, a holding statement.	File regulator notifications where a clock requires it. Notify directly affected third parties and major customers privately, one to one.	Issue a public statement only if warranted. Brief the full board on confirmed facts. Log every clock and every notification sent.

PART 5

90-Day Hardening Roadmap

Ten prioritised controls mapped to the failure modes of 2025–2026

Use it when the incident is contained, or you want to act before one. Quick Wins can start this week, in parallel with any response.

The controls are tiered by how quickly they can realistically be deployed, not by importance. Each one closes a specific failure mode exploited in real 2025–2026 campaigns across npm, PyPI and GitHub Actions. The Quick Wins cost little and close the doors these campaigns walked through most often.

QUICK WINS

Under 2 weeks

	Control and rationale	Addresses	Effort	Owner
☐	Pin every third-party GitHub Action to a full commit SHA, and enforce it by organisation policy Mutable tags let an attacker silently rewrite a release. In the March 2026 Trivy compromise, 75 of 76 trivy-action tags were repointed to malicious commits in a single burst; SHA pinning makes that rewrite inert. Pin CI job images by digest for the same reason.	Tag-rewrite attacks	Low	Platform Eng.
☐	Ban privileged workflows that run pull-request code (pull_request_target “pwn requests”) This pattern seeded the 2025 Nx compromise, the February 2026 Trivy breach and the May 2026 TanStack cache-poisoning attack. Remove or rewrite every such workflow, and make a workflow linter (for example zizmor or actionlint) a required check.	Untrusted code with secrets	Low–Med	AppSec
☐	Move npm and PyPI publishing to trusted publishing (OIDC) and revoke long-lived publish tokens Long-lived tokens are what self-propagating worms harvest and reuse. Bind trusted publishing to a protected environment that only the default branch or a protected tag can use, then disallow token-based publishing on each package.	Token-harvest worms	Medium	Engineering
☐	Apply a minimum release age (cooldown) to non-security dependency updates Most malicious versions in 2025–2026 were detected and removed within days. A seven-day release age (pnpm, Yarn or Bun settings, or Renovate and Dependabot cooldowns) skips them automatically, with a documented fast path for security fixes.	Fast-moving worms	Low	Platform Eng.

MEDIUM TERM

Within 30 days

	Control and rationale	Addresses	Effort	Owner
☐	Deploy SCA with continuous SBOM generation for every production service and CI tool Organisations with a live SBOM answered “are we affected?” in minutes during the largest 2025 worm outbreaks; others needed days. Target: under 15 minutes for any package, including actions and developer tooling.	Detection speed	Medium	AppSec

	Control and rationale	Addresses	Effort	Owner
☐	Isolate CI/CD build environments and restrict runner egress Most 2025–2026 stealers exfiltrated from build runners, some through blockchain-hosted command channels chosen because they are hard to block. Allow-list outbound destinations for release and publish jobs first, then all privileged jobs.	Exfiltration	Med–High	Platform Eng.
☐	Match supply chain intelligence feeds to your SBOM automatically Ingest OSV, the GitHub Advisory Database, CISA KEV and vendor malicious-package feeds into the SIEM and match them to the SBOM, so a public advisory becomes an internal ticket naming affected services.	Early detection	Medium	SecOps

STRATEGIC

Within 90 days

	Control and rationale	Addresses	Effort	Owner
☐	Run secret scanning with automated rotation triggers across all CI/CD pipelines Turns the Atomic Rotation Protocol (Part 2) from a manual scramble into a response that fires the moment a secret appears in the wrong place, closing the gap that let several campaigns persist after their first “containment”.	Credential theft	High	SecOps / Plat. Eng.
☐	Run tabletop exercises on this toolkit's scenarios at least twice a year In every major 2025–2026 campaign the most costly failures were decisions, not tools. Time each exercise against the 30-minute and 24-hour targets in Parts 1 and 4.	Decision readiness	Medium	CISO
☐	Agree a supply chain incident notification protocol with critical vendors In several 2025–2026 cascades, compromised versions reached downstream customers before any notification channel existed. Agree contacts, timelines and the information to be shared (versions, windows, indicators) in contracts.	Cascade response	Medium	CISO / Legal